



SASKEN



Android Security Maintenance Release and Device Update

Abstract:

Android holds the lead in the world of operating systems with a market share of over 70%. This growing trend in usage of Android devices in both consumer and enterprise segments has increased the risk of threats and vulnerabilities. Safeguarding Android devices from malware and other cyber threats is of paramount importance. OEMs face multiple challenges in managing these security upgrades. This paper explores the different stages and activities involved in updating device security level and strategies to optimize the efforts & rollouts of security updates.

Author:

Vinay Harugop - Architect-Software,
Sasken Technologies Limited.



Table of Content

Introduction	4
Terms and definitions	5
Challenges in Device “Security Level” update	6
Understanding Android Security Bulletin	8
Android open-source components fixes	9
Linux kernel and Vendor open component	9
Vendor closed source component	10
Vendor firmware version upgrade	10
Backporting Android Security bulletin	11
Verification of ASB and GMS Certification	12
Partnering with Sasken for Android security update	14
Conclusion	15
References	15
About the Author	16
About Sasken	16



Introduction

Software and firmware vulnerability issues are considered as part of Common Vulnerabilities and Exposures (CVE) published and maintained by [MITR](#) corporation. CVEs are reported from internal android research and pre-published by academic research, open-source projects, chipset vendor, device manufacturer partners, and publicly disclosed issues. It is important to constantly update the Android security level with security fixes against possible vulnerabilities.

Android operating system has a market share of around 70%. This growing trend and usage of Android devices in different industries, especially in the enterprise context, raises question on the extent to which these devices are updated to stay safe from known CVEs. Android is an open-source software with applications running on hardware and latest software components which communicate over the network thereby making the platform vulnerable. Cyber criminals can launch attacks on users and cause damage to the device which can lead to financial & reputation losses. Few examples of such security attacks publicly known are Toast Overlay attack: TOASTAMIGO and BlueBorne.

Google publishes the android security bulletin every month with a full list of known CVEs and the necessary security updates. It's the need of the hour for Android OEMs and device manufacturers to ensure that these fixes are promptly incorporated in their monthly software updates in a sustainable manner.

This whitepaper suggests how OEMs can ensure timely management of Android security fixes. The paper underlines a proven and systematic approach to optimally manage the software update process. This whitepaper explains,

- The challenges faced by OEMs to manage security updates and the possible ways to optimize the whole process
- Handling android security fixes, criteria for testing and GMS compliance impact
- Impact on certification and chipset firmware modem upgrade

This whitepaper also provides an insight on the unique and proven methodology developed by Sasken to address Android security management.



Terms and definitions

Term	Description
OEM	Original Equipment Manufacturer
ASB	Android Security Bulletin
CVE	Common Vulnerability Exposure
Chipset vendor	Qualcomm, Intel, MediaTek, Broadcom, Nvidia
GMS compliance	Android Test Suites (CTS, STS, GTS, VTS, CTSV, cts-on-gsi, cts instant)
SKU	Stock Keeping Unit
3PL	Google designated 3rd party labs for certifying
NDA	Non-Disclosure Agreement
SPL	Security Patch Level
CR	Change request (QUALCOMM)
EOL	End of Life (chipset vendor software project support state)
TAM	Technical Account Manager
GSI	Android Generic System Image
MADA	Mobile Application Distribution Agreement – GMS License

Table 1: Terms and definitions



Challenges in Device “Security Level” update

The Android platform features a multi-layer architecture which includes open-source components, Linux kernel and semiconductor (chipset specific) closed and open components. Google provides fixes for CVEs publicly in Android Security Bulletin which is published every month to partners and device manufacturers. The list of security fixes are classified as patch levels 1 and 5. The two patch level nomenclature gives flexibility to device manufacturers to address the subset of vulnerabilities quickly across all their Android devices.

Devices with Security Patch level 1 must include all current month patch level 1 security fixes and patch level 1 fixes from the previous security bulletin. Usually patch level 1 fixes span across AOSP components. Devices with security patch level 5 must include current month patch level 5 security fixes and patch level 5 fixes from all previous security bulletins. Typically patch level 5 security fixes span across mainstream open components, vendor closed components and need more time to manage and integrate.

OEMs must integrate these security fixes and decide to rollout security level updates regularly to secure end-user devices. When including these fixes, device manufacturers need to make sure their customizations are intact and stable post the upgrades.

Google mandates that OEMs execute Android compliance test suites and ensure that the software is certified by 3PL. This certification includes Google GMS certification and operator certification.

Carrier certification need to be done in case of modem and connectivity CVE are integrated and which may have impact on operator specifications/certification.

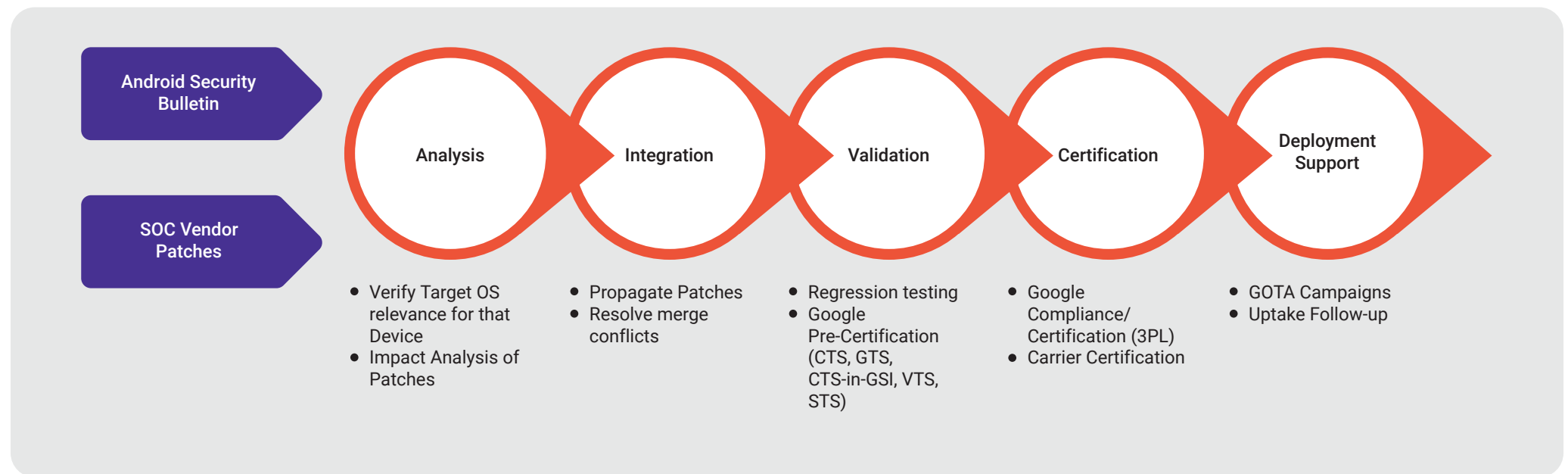
Below are the list of tasks OEMs perform each month to roll out the security updates:

- Analyze and integrate each patch level 1 and level 5 CVE fixes.
- Verify vulnerabilities fixed and execute GMS compliance test suits.
- Fix or conclude any new and existing failures and negotiate waiver request if required.



Once above tasks are completed, the OEM gets the software image certified with 3PL designated by Google. This process is applicable to OEMs for all the SKUs/products variants running on different Android versions and repeated for each ASB.

Android Security Management Process

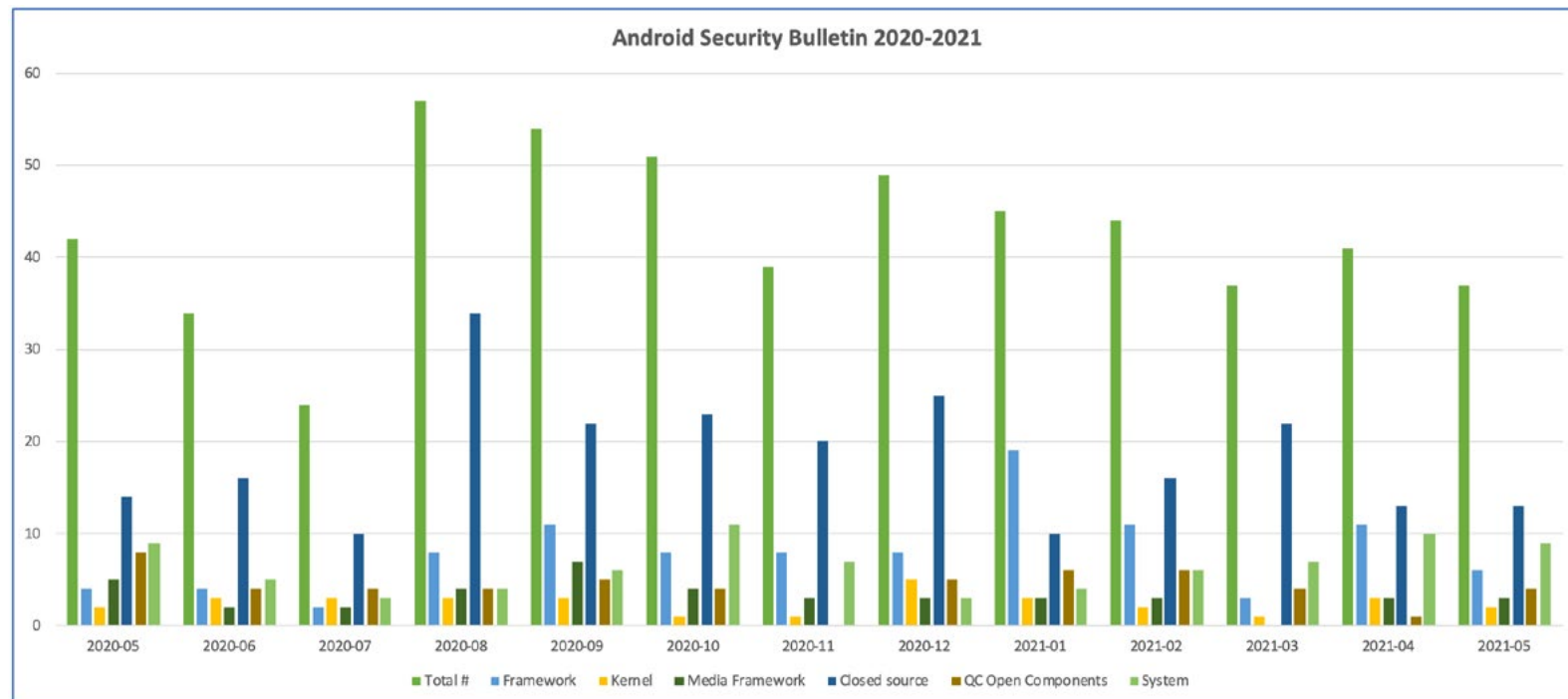


Understanding Android Security Bulletin

The Android security team publishes Android Security Bulletin (ASB) bundles with the list of CVEs on the first Monday of every month. The ASB bundle is made available to OEMs one month prior to public announcement. The Android security bundle contains the archive of security patches, updated STS test suits, CVE description document and preview document of all listed CVEs.

The ASB preview document furnishes the list of CVE numbers, their reference Android bug ID, type, severity and applicable android versions and components. These CVEs are distributed across kernel, media framework, connectivity, runtime components, application framework, chipset open and closed source components, and patch level classification.

The following graph depicts ASB component wise publish for past one year.



Android open-source components fixes

Security vulnerability fixes in the android framework, applications, system (BT, WIFI, NFC, System UI) layers are classified as patch level 1. It is mandatory to include these fixes to update SPL in the device to “<year><month>-01” with all previous security bulletin patch level 1 fixes.

Android open-source component’s security fixes may apply directly or some time they may have a dependency on the previous changes. In such scenarios it is important to maintain integrity of the code by taking all previous dependencies and bringing the code base to latest version before making any security related fixes.

These components of Android most likely have OEM customizations for operator compliance, OEM specific features and bug fixes. Security fixes need to be analysed for their applicability in relation to the specific OEM code base. OEM code customization changes may conflict with the vulnerability fixes in some cases. These conflicts need to be fixed to avoid any adverse impact on customization. There may arise the need to make suitable modifications to the code to ensure seamless integration of the fixes.

Based on the security fix, the test scenarios need to be decided to verify the fix and their impact on the target module. Existing test cases in android compliance test suites can be used to verify and a test procedure, test application or script needs to be developed.

Linux kernel and Vendor open component

Security fixes for the Linux kernel are made available from the common android kernel tree. These fixes are propagated from Linux kernel mainline to Android common kernel. These fixes will be across the kernel’s internal parts (file system, drivers, network, display, graphics etc). Security fixes listed under this category are usually classified as Patch level 5.

To undertake kernel fixes, the usual practice is to download the differences, check for recursive dependency or kernel version mismatch for the security fix being applied. In such an event, it is necessary to refer to the kernel mainline and analyse & integrate all the previous kernel dependent patches.

Chipset vendor fixes typically taken from vendor components published as open source. It is necessary to check the applicability of these fixes and in case of ambiguity, can discuss with chipset vendor and get the appropriate fix. Security fixes listed under this category are usually classified as Patch level 5 due to dependency on chipset vendor and mainline component. There are instances where dependency on closed components will arise. In this case it is a challenge to sync multiple components and plan for integration and verification.

Based on the fix and modified components, a test spec is created to include OS tests, functionality tests, stability tests and use case verification.



Vendor closed source component

Security fixes listed under this category are usually classified as Patch level 5 due to dependency on chipset vendor closed components. Vendor closed components are not public and exists either in binary format or source format. These CVEs need to be discussed with the chipset vendor prior to applying the fix, integration and testing which is a time-consuming task. It is a requirement to include these issues and all previous month issues to set complete SPL to “<year><month>-05”.

Closed source component security fixes are provided in binary and source format. But these need to be received directly from chipset vendor only. The most crucial thing in this process is to maintain software revision, build ID and release tags in OEM & chipset vendor code base. In case of mismatch, there is a huge impact on compliance test report.

Every chipset vendor has a unique way of providing their closed source component deliveries. Few important closed components which will have security fixes are BOOT, DSP, WLAN, BT, MODEM, Trustzone, Video etc.

Testing of fixes for the closed components is slightly challenging as few security fixes may need testing at protocol levels. These will depend on infrastructure/lab facility.

Vendor firmware version upgrade

Closed source security issues are fixed and maintained in the latest release by chipset vendors. When current firmware version is dated, it is difficult for chipset vendor to provide the fix. Firmware version upgrade involves rebasing both firmware and high-level components of the Android operating system. Version upgrade is resource intensive as it may impact certification and impact device stability and regression and hence increase the financial burden to the OEMs.

To maintain the latest SPL, it becomes necessary to upgrade firmware versions in short time due to the following reasons:

- As we incorporate the ASB month-by-month, the backlog of vendor dependent patch level 5 CR list balloons rapidly. This will block the setting of SPL in the device and may delay the pre-agreed software update roll out planned with operator.
- The branch of software product line may reach EOL at the chipset vendor. In this scenario the chipset vendor will recommend upgrading firmware version to the latest branch.

During the firmware upgrade phase, there is a need for a close analysis of all the CRs included in latest firmware release content. This analysis includes understanding security CRs and non- security fixes (features, CR). Based on the CR analysis, we may



need to discuss with the chipset vendor TAM for clarity on certification and support level, new firmware lifetime among others.

OEM customizations in closed components may include operator specific requirements, device specifications, hardware tuning values and certain issue fixes. Firmware upgrade for closed components must be done without impacting OEM customizations, which is the most crucial part in version upgrade process.

Firmware upgrades have a huge impact on testing due to the volume of changes in both HLOS and non-HLOS. It becomes inevitable to execute system tests, regression tests, functionality tests, duration tests and finally GMS compliances & certification tests on all SKUs.

Backporting Android Security bulletin

Many Android devices in the market run the older versions of Android such as Android 6 and Android 7, particularly in the enterprise domain. Once Google stops support for Android security releases for older Android versions, OEMs may decide to continue to provide security updates to ensure their brands stays competitive and continue to thrive in the market. For example, as of today, Android 6 (Marshmallow), Android 7 (Nougat) and Android 8.0 (Oreo) devices may have to be updated with security fixes from Google.

Backporting of Android security bulletin security fixes depends on the existing code compatibility and versions of certain components. In case the code is incompatible, there is possibility of missing files, methods or changed methods due to version mismatch. In such scenarios security fixes will be adopted according to code base and thoroughly tested for the code reachability.

To handle vendor closed source patches, it is necessary to check with semiconductor chipset vendors for EOL of the dated Android version platform. Usually, chipset vendor's support for dated Android versions end before Google's support is terminated. In certain situations, it might be necessary to use vendor firmware version upgrades.

GMS compliance test suite versions are frozen to the latest version when Google support is ended. For example, Android 6.0, CTS release version [R32](#) is utilized to ensure that the test report are consistent as per the previous report and backporting new Android security bulletin has not broken the system and APIS.



Verification of ASB and GMS Certification

Vulnerability fixes from Android security bulletin impacts all software components. It is necessary to verify the impact on functionality, Android APIs, vendor components, closed source CR included or not and impact on GMS certification. Verification for GMS certification is done by 3PL on the software image provided by the OEM. OEMs need to ensure that they obtain a satisfactory test report of all Android compliance test suits.

Google publishes GMS compliance test suites regularly with changes for all latest Android versions. As code changes occur in Android components, test suites also undergo many changes for the addition or deletion of test cases. Sometime test implementations are modified due to changes introduced by security fixes.

GMS compliance test includes:

- **CTS: Compatibility Test Suites**

Released regularly for all Android versions which is available publicly for download. Verifies Android APIs and features. Android 10 CTS has roughly around 1190642 test cases

- **STS: Security Test Suit**

Released every month along with ASB to verify security level in device & closed component and important open component CVEs. STS also verifies SPL string PLATFORM_SUCRITY_PATCH is set to correct security level or not. Android 10 latest STS has roughly around 772 test cases

- **GTS: GMS test suit**

Released regularly for all Android versions to OEM under MADA License. Test suites verify GMS applications are compatible with the device. Android 10 latest GTS has roughly around 3141 test cases

- **VTS: Android Vendor test Suit**

Test suite to confirm Treble architecture implementation that splits hardware independent core framework in Java from hardware dependent vendor implementation and cross layer communication them. Executed with Google provided Android GSI image. Android 10 latest VTS has roughly around 10114 test cases



- **CTSV: CTS Verifier**

Manually executed specific tests for which manual interaction is needed. Android 10 latest CTSV has roughly around 105 test cases

- **CTS-on-GSI:**

Limited version of CTS which is executed on GSI image. Android 10 latest cts-on-gsi has roughly around 579994 test cases

- **CTS-instant:**

It is stripped down version of CTS to ensure android instant app work correctly and critical security have been applied. From Android 10 onwards, this is part of CTS.

Usually, GMS compliance test executions take a week for the latest android versions on multiple devices with multiple iterations. The compliance test execution environment needs proper setup and equipment. A dedicated lab with networking, camera ITS setup and systems with compatible Ubuntu Linux and python versions. Google provides a test harness trade fed that helps to execute Android automated tests. TF test hosts

and monitors the connected devices, handling test scheduling & execution and device management. GMS test suites generates test report which contains results in xml format with pass and failure logs. It is expected that all tests are passed but due to some reason there may be failures. These test failures are analysed as outlined below:

- Check for existing waiver and possible new waivers.
- Fix under review in Android source CTS project mainline for which waiver is asked.
- Impact due to security fix or changes/features introduced by OEM, which needs to be fixed.
- Failed due to setup issues or environment changes.



Partnering with Sasken for Android security update

Sasken has been working on the Android platform since its launch in 2009. With an immense experience in Android upgrades and relationships with different semiconductor modules, Sasken has set up a dedicated state-of-the-art lab and developed Android SMR CoE with a unique way of handling Android security updates to address:

- Current and latest Android versions
- Back porting to older Android version (Marshmallow, Nougat)
- Various vendor/semiconductor components version upgrade
- Different industry segments
 - » Rugged enterprise devices
 - » Consumer devices

Sasken has set up a common process across multiple platforms to address Android security updates. Based on re-usability of certain work products, optimizations of ASB handling is executed ensuring a smooth roll-out of scheduled device updates by device manufacturers.



Conclusion

The Android operating system continues to evolve with immense new features, maturing day by day. Though devices are safe, it is difficult to eliminate security threats and protecting these devices from such vulnerabilities is a must.

In this technical whitepaper, we have provided some insights into Android security management and deploying monthly Android Security Bulletins for latest and older Android devices. This technical whitepaper gives an overview on different stages and activities involved in updating device security level and challenges to support strategy making process for Original Equipment Manufacturers to optimize the efforts and rollout security updates regularly without many delays.

In our experience, it is possible to re-use some part of the work across multiple devices and optimize efforts and cost.

References

1. <https://source.android.com/security/bulletin>
2. <https://source.android.com/compatibility/cts/downloads>
3. <https://android.googlesource.com/kernel/common/>
4. <https://source.codeaurora.org/>
5. <https://cve.mitre.org/index.html>
6. <https://www.programmersought.com/article/1288117057/>
7. <https://android-developers.googleblog.com/2017/05/here-comes-treble-modular-base-for.html>
8. https://source.android.com/devices/tech/test_infra/tradefed



About the Author

Vinay Harugop has almost two decades of experience in Linux based embedded systems and mobile platform development. At Sasken, he works for the smart devices and is responsible for development and delivery.

About Sasken

Sasken is a specialist in Product Engineering and Digital Transformation providing concept-to-market, chip-to-cognition R&D services to global leaders in Semiconductor, Automotive, Industrials, Consumer Electronics, Enterprise Devices, SatCom, Telecom, and Transportation industries. For over 30 years and with multiple patents, Sasken has transformed the businesses of 100+ Fortune 500 companies, powering more than a billion devices through its services and IP.





SASKEN



Android Security Maintenance Release and Device Update

marketing@sasken.com | www.sasken.com

USA | UK | FINLAND | GERMANY | JAPAN | INDIA

© Sasken Technologies Ltd. All rights reserved.

Products and services mentioned herein are trademarks and service marks of Sasken Technologies Ltd., or the respective companies.